later than 72 hours after becoming aware that the breach has occurred. This provision might also result in a number of service providers adapting their businesses processes. However, considering that 24 states require entities that maintain but do not own or license customer information data to notify the entity that owns or licenses such data "immediately" in case of a breach of security, we expect that many service providers already have processes in place to ensure that such notification is made.[930] For the service providers who do not already have such processes in place, this approach will create benefits for the customers who will be informed in a timely manner in the event their sensitive information is compromised.

Third, because the final amendments require covered institutions to establish, maintain, and enforce written policies and procedures reasonably designed to require oversight, including through due diligence and monitoring, of service providers who have access to their customers' information, these service providers will face requests for information from covered institutions or otherwise participate in the covered institutions' oversight activities. This will impose costs on service providers, but it will also strengthen the benefits of the amendments by helping ensure that customer information is appropriately protected even when it is residing in service providers' systems.

For service providers that provide specialized services aimed at covered institutions, the final amendments may create market pressure to enhance service offerings that facilitate covered institutions' compliance with the requirements.[931] Such enhancement will entail costs for specialized service providers, including the actual cost of adapting business processes, as

---

[930] In addition, other existing regulations have 72-hour reporting or notification deadlines. *See supra* footnote 257 and accompanying text; *see also supra* footnote 245.

[931] A service provider involved in any business-critical function likely "receives, maintains, processes, or otherwise is permitted access to customer information." *See* final rule 248.30(d)(10).

discussed above, to accommodate the requirements.[932] That said, we do not expect that these costs will represent an undue burden as both the specialized service providers and the covered institutions are operating in a highly regulated industry and might be accustomed to adapting their business processes to meet regulatory requirements. Moreover, more specialized service providers may be likely to have particularly sensitive or valuable information about the customers of covered institutions, and therefore the investor protection benefits in those cases may be substantial. With respect to service providers providing services aimed at a broad range of institutions, such as those providing email or customer-relationship management services, covered institutions are likely to represent a small fraction of their customer base. These service providers may be unwilling to adapt their business processes to the regulatory requirements of a small subset of their customers if they do not already have such processes in place.

For the service providers that already have in place processes satisfying the covered institutions' requirements, we expect that the costs to both the service providers and the covered institutions will be minimal and will mostly result from covered institutions' oversight duties. If service providers modify their business processes to facilitate covered institutions' compliance with the final amendments' requirements, we anticipate they likely will pass costs on to covered institutions, and ultimately covered institutions may pass these costs on to customers.[933] We also expect that there might be a fraction of service providers who will be unwilling to take the steps necessary to facilitate covered institutions' compliance with the final amendments. In such cases, the covered institutions will need to either switch service providers and bear the associated

---

932 We have no data on the number of specialized service providers used by covered institutions and on the frequency with which these service providers already adapt their business processes to regulatory changes, and no commenter suggested such data.

933 *See supra* footnote 718.

switching costs or perform the functions in-house and establish the appropriate processes as a result.[934] We expect that these costs will be particularly acute for smaller covered institutions which lack bargaining power with large service providers, and that these costs might be passed on to customers.[935] However, the amendments will create benefits arising from enhanced efficacy of the regulation.[936]

The proposal included a requirement that a covered institution's response program must include written policies and procedures requiring the institution, pursuant to a written contract between the covered institution and its service providers, to require that service providers take appropriate measures that are designed to protect against unauthorized access to or use of customer information.[937] While one commenter supported this proposed requirement,[938] other commenters suggested that the final amendments not require written contracts with service providers,[939] stating that doing so would impose significant costs on covered institutions.[940] After

---

934 Such switching costs could include the time and other resources necessary to find an alternative service provider, conduct appropriate due diligence, and negotiate prices and services provided. Performing the functions in-house may also be more costly than outsourcing them for covered institutions. A recent report finds that 73% of surveyed asset managers cite cost considerations when deploying outsourcing solutions. *See* Cerulli Report. The competitive effects associated with the cases where service providers choose to stop providing services to covered institutions as a result of the final amendments are discussed below. *See infra* section IV.E.

935 We expect that smaller covered institutions may be less able to pass these costs to customers. *See supra* footnote 718.

936 From the perspective of current or potential customers, the implications of customer information safeguard failures are similar whether the failure occurs at a covered institution or at one of its service providers.

937 *See* proposed rule 248.30(b)(5)(i).

938 *See* ICI Comment Letter 1.

939 *See, e.g.*, SIFMA Comment Letter 2; IAA Comment Letter 1.

940 *See, e.g.*, SIFMA Comment Letter 2 ("Requiring each service provider to revise its contract with a covered institution within 12 months of the Proposal's finalization would add an unnecessary burden to both covered institutions and service providers, as well as a potential significant cost."); IAA Comment Letter 1 ("Even if Service Providers agreed to enter into written agreements with advisers as proposed, advisers and Service Providers would both likely incur significant negotiation and implementation costs, which we do not believe are justified, especially when an alternative and less burdensome approach is available."); STA Comment Letter 2 (stating that "transfer agents, because of their relatively small size, simply do not have the negotiating power to demand contractual terms requiring third party service providers to maintain

considering these comments, we are requiring that covered institutions establish, maintain, and enforce written policies and procedures to require oversight of service providers instead of requiring written contracts.[941] This change, while enhancing the policies and procedures obligations, will provide covered institutions with greater flexibility in achieving compliance with the requirements, which could reduce compliance costs without significantly reducing the benefits of the final amendments.[942] Providing this flexibility will also help address commenters' concerns that requiring a written contractual agreement could harm covered institutions, particularly those that are relatively small and may not have sufficient negotiating power or leverage to demand specific contractual provisions from a larger third-party service provider.[943] However, in a scenario where a covered institution has an existing contract with a service provider that is renegotiated as a result of the final amendments, the covered institution may incur additional costs.[944] In addition, in a scenario where a service provider would have agreed to a written contract under the proposed amendments but will not under the final amendments, a covered institution may have to exert greater efforts to oversee this service provider than would have been necessary had it signed a written contract with this service provider.[945]

---

certain policies and procedures, or to demand permission to perform due diligence on a service provider's systems, policies, and procedures.").

941 *See supra* section II.A.4 and final rule 248.30(a)(5).

942 See supra section II.A.4; *see also, e.g.*, AWS Comment Letter.

943 *See, e.g.*, IAA Comment Letter 1.

944 It is difficult for us to quantify these costs, as we have no data on the provisions of existing contracts between covered institutions and their service providers relating to customer information safeguards, and no commenter suggested such data. Such costs are likely to be contract specific, as they will depend on the degree to which each existing contract may be revised as a result of the final amendments. Many such contracts may not be revised at all, while others may undergo more revisions. Moreover, in many cases, even where a contract could be revised as a means of complying with the final requirements, the covered institution may pursue compliance by other means.

945 There are a variety of ways in which covered institutions will be able to satisfy the oversight requirement. *See supra* section II.A.4.

We also proposed that the measures taken by service providers include notification to the covered institution as soon as possible, but no later than 48 hours after becoming aware of a breach in security resulting in unauthorized access to a customer information system maintained by the service provider.[946] While one commenter supported this proposed requirement,[947] other commenters stated that a longer deadline would be preferable.[948] One commenter also suggested a change from "becoming aware" to "determining" that a breach has occurred in order to minimize pressure to report on service providers while an investigation is being conducted.[949]

After considering these comments, we have changed this provision. The final amendments require covered institutions to ensure that their service providers notify them of a breach as soon as possible, but no later than 72 hours after becoming aware that an applicable breach has occurred.[950] We expect that the change to 72 hours will reduce the cost to service providers not only because it will give them more time to assess an incident before notifying the covered institution, but also because it aligns with existing regulation.[951] Hence, we expect that this change will decrease compliance costs for covered institutions by making service providers more likely to agree to the requirements, which will decrease negotiation and switching costs for

---

946 *See* proposed rule 248.30(b)(5)(i).

947 *See* ICI Comment Letter 1 ("We concur with the Commission requiring service providers to notify a covered institution notice within 48 hours of a breach impacting the covered institution or its affected individuals.").

948 *See, e.g.*, Microsoft Comment Letter ("Specifically, where the SEC determines that a cybersecurity incident reporting requirement is appropriate, the applicable rule should provide that the entity with the notification responsibility shall provide the required notice to the recipient as soon as possible but no later than 72 hours. The reporting deadline should begin to run once the entity with notification responsibilities has a reasonable basis to conclude that a notifiable incident has occurred or is occurring."); ACLI Comment Letter ("In the early days of containment and remediation it is often difficult to determine exactly what data has been compromised, making the 48-hour timeframe overly short and burdensome.").

949 *See* Google Comment Letter.

950 *See* final rule 248.30(a)(5)(i).

951 *See supra* footnote 257 and accompanying text.

covered institutions.[952] We also expect that this will alleviate some of the commenters' concerns about having insufficient negotiating power to negotiate specific with service providers.[953] While this change may result in a longer period of time before customers receive notification of a breach, thereby decreasing the benefits of such notification,[954] it might also reduce the number of unnecessary notifications to covered institutions and, in turn, to customers.[955]

The final amendments provide, as proposed, that a covered institution may enter into a written agreement with a service provider to notify individuals affected by a breach on the covered institution's behalf.[956] Some commenters supported this proposed requirement.[957] We expect that this provision could reduce the compliance costs of the amendments, especially in the case where the breach happens at the service provider. In this case, the service provider may be in a better position to collect the relevant information and provide the required notice to customers.[958]

---

952 Alignment with existing regulation makes it more likely that service providers already have policies and procedures in place to comply with this requirement.

953 *See, e.g.*, STA Comment Letter 2.

954 *See supra* section IV.D.1.b(2) for a discussion of the benefits of a timely notice to customers.

955 *See* Microsoft Comment Letter ("Premature reporting according to a 48-hour or shorter deadline, in our experience, increases the likelihood of reporting inaccurate or incomplete information, which is of little-to-no value and tends to create confusion and uncertainty."). *See also supra* section IV.D.1.b(4) for a discussion of the effects of unnecessary notification. We expect that the change made to the notification timing requirements for service providers will mitigate these effects.

956 *See* final rule 248.30(a)(5)(ii).

957 *See* Schulte Comment Letter ("Covered Institutions should be permitted to reach commercial agreements that delegate notice obligations to service providers, as long as the notice actually provided to customers with potentially impacted data satisfies the Covered Institution's notice obligations."); ICI Comment Letter 1 ("We also concur with the Commission that covered institutions should be permitted to have their service providers send breach notices to affected individuals on behalf of the covered institution.").

958 One commenter stated that "if the service provider was the victim of a cyber attack that included unauthorized access to Covered Institution sensitive customer information, then the service provider would be better situated to notify the affected customers." *See* Schulte Comment Letter. Even when the service provider notifies customers directly, the obligation to ensure that the affected individuals are notified rests with the covered institution. *See supra* section II.A.4 and final rule 248.30(a)(5)(iii).

It is possible that a breach that will trigger a notification obligation might occur at a covered institution that will also be a service provider to another covered institution.[959] The final amendments provide that the obligation to ensure that affected individuals are notified rests with the covered institution where the breach occurred.[960] If this covered institution is also a service provider to another covered institution, it retains the obligation, as a service provider, to notify this other covered institution of the breach.[961] This will allow the other covered institution to initiate its own incident response program and to perform its oversight duties on its service providers, and contribute to enhance the protection of customer information. We modified the final amendments such that only one covered institution needs to notify the affected customers.[962] By requiring only one notice to be sent for a given incident, this modification will reduce compliance costs—since only one covered institution will have to devote resources to preparing and sending the notice—and reduce potential confusion for the affected customers.[963] We do not expect this modification to reduce the benefit for such customers, who will still receive a timely notice.

---

959 For additional discussions of the cases where multiple covered institutions are involved in the same incident, *see supra* section II.A.3.a and *infra* section IV.D.2.a.

960 The amendments allow the two covered institutions to coordinate with each other as to which institution will send the notice to the affected individuals. *See supra* section II.A.3.a.

961 Because this service provider is itself a covered institution, it will have appropriate policies and procedures in place. Hence, we do not expect that notifying the other covered institution will imply significant costs.

962 *See supra* section II.A.3.a. Some commenters stated that the proposed amendments could be interpreted to lead to duplicative notices. *See, e.g.*, CAI Comment Letter ("This dynamic could also create duplicative notification obligations where there is unauthorized access to sensitive customer information that is held or maintained by one financial institution on behalf of another, since proposed Rule 30 [sic – rule 248.30] notification obligations would appear to apply to both financial institutions simultaneously even though only one set of customer information was accessed."). The revisions specify that only one notification is required in that circumstance.

963 Duplicative notices may nevertheless happen as a result of different requirements from other existing regulations. *See supra* section IV.C.2.a(3).

2. Extending the Scope of the Safeguards Rule and the Disposal Rule

a. Definition of Customer Information

The final amendments more closely align the scope of the safeguards rule with the scope of the disposal rule. They also broaden the scope of information covered by the rules to all customer information, regardless of whether the customers are a covered institution's own, or those of another financial institution whose customer information has been provided to the covered institution.[964] The final amendments define customer information, for any covered institution other than a transfer agent, as "any record containing nonpublic personal information" about a customer of a financial institution, whether in paper, electronic or other form, that is in the possession of a covered institution or that is handled or maintained by the covered institution or on its behalf. Such information is customer information regardless of whether it pertains to (a) individuals with whom the covered institution has a customer relationship or (b) the customers of other financial institutions where such information has been provided to the covered institution.[965] For transfer agents, customer information is defined as any record containing nonpublic personal information "identified with any natural person, who is a securityholder of an issuer for which the transfer agent acts or has acted as transfer agent, that is handled or maintained by the transfer agent or on its behalf."[966]

While some commenters supported the proposed scope of the rules regarding the definition of customer information,[967] one commenter stated that the rule should focus on sensitive customer information, and that the breadth of the proposed amendments was

---

964 *See supra* section II.A.3.a.

965 Final rule 248.30(d)(5)(i).

966 Final rule 248.30(d)(5)(ii).

967 *See, e.g.*, EPIC Comment Letter; Better Markets Comment Letter.

disproportionate to the risks of disclosure.[968] This commenter also stated that applying the service provider requirements to all service providers that have access to any customer information would be disproportionate to the benefits and risk presented and suggested that it apply only to service providers with access to sensitive customer information.[969]

We acknowledge that applying the policies and procedures requirements to all customer information will impose costs that would not be incurred if the amendments covered only sensitive customer information. However, this approach creates important benefits. For example, the disclosure of customer information could be used for phishing attacks or similar efforts to access sensitive customer information. Moreover, with respect to policies and procedures specifically, the costs of creating policies and procedures for all information should not be much larger than the cost of creating them for only sensitive customer information, because the cost is in the creation of the policies and procedures rather than in their application. We acknowledge, however, that in some organizations the sensitive customer information could be located in different systems or accessible to different employees, such that policies and procedures for non-sensitive information would be different. In addition, covered institutions' existing policies and procedures may be less likely to meet the new requirements as a result of the breadth of the definition and would thus require modifications.

Because the final amendments extend the scope of customer information subject to protection to information possessed by a covered institution regardless of whether the customers are a covered institution's own, or those of another financial institution whose customer information has been provided to the covered institution, the benefits of the final amendments

---

968 *See* IAA Comment Letter 1.

969 *See* IAA Comment Letter 1.

will extend to a wide range of individuals such as prospective customers, account beneficiaries, recipients of wire transfers, or any other individual whose customer information a covered institution comes to possess, so long as the individuals are customers of a financial institution.[970] We anticipate that, in many instances, the preventative measures taken by covered institutions to safeguard customer information in response to the final amendments will generally also protect these additional individuals.[971] Hence, while we expect that these measures could have potential significant benefits for these additional individuals, we do not expect them to result in significant additional costs for the covered institutions. However, we acknowledge that, in certain instances, this may not be the case. For example, information about prospective customers used for sales or marketing purposes may be housed in separate systems from the covered institution's "core" customer account management systems and require additional efforts to secure. Regarding the measures taken by covered institutions to comply with the final amendments' incident response program requirements, following a data breach, we do not anticipate that extending the scope of information covered by the final amendments to include these additional individuals will have a significant effect. These costs will include additional reputational harm and litigation as well as increased notice delivery costs. However, given that the distinction between customers and other individuals is generally not relevant under existing state notification laws—which apply to information pertaining to residents of a given state—we expect that most covered institutions will have already undertaken to protect and provide notification of data breaches to these additional individuals.

---

970 *See* final rule 248.30(d)(5).

971 For example, measures aimed at strengthening information safeguards such as improved user access control or staff training will likely protect a covered institution's customer information systems regardless of whether they house the information of the covered institution's own customers or those of another financial institution.